

What Is Pentesting? How Does It Work Step-by-Step?

Which pentesting method is right for your organization? [Download the Pentest Matrix Ebook](#)

What is Pentesting?

Penetration testing, aka pen testing or ethical hacking, attempts to breach a system's security for the purpose of vulnerability identification.

In most cases, both humans and automated programs research, probe, and attack a network using various methods and channels. Once inside the network, penetration testers will see exactly how deep they can get into a network with the ultimate goal of achieving full administrative access, or "root."

While this may sound frightening, it's a growing trend that some of the biggest companies worldwide use to stay one step ahead of malicious actors. By purposely attacking your own network, you discover your organization's vulnerabilities before a potential breach.

This is part of an extensive series of guides about [data security](#).

How Exactly Does Pentesting Work?

Pen testing utilizes ethical hackers to put themselves in the shoes of malicious actors. Network owners establish a specific pentesting scope that specifies what systems are eligible for testing and the test timeframe.

Determining scope sets guidelines and sets the tone and limitations for what the testers can and cannot do. After a scope and timeframe have been established, the ethical hackers get to work scanning for ways into the network.

Tests usually start with a vulnerability scan that helps identify potential doorways into a network. These vulnerabilities could be anything from misconfigured firewalls to applications that improperly process malformed packets.

Once a system is compromised, the tester can then attempt to gain access to privileged accounts to research deeper into the network and access more critical systems. Pentesters use escalation techniques to investigate a network and explore what a worst-case scenario might be.

Depending on the pentest scope, tests can use several unconventional ways to gain access to networks. One of those techniques is to drop infected USB drives in an organization. If an untrained staff member finds that drive and plugs it into the company network, it could springboard the simulated attack to gain access even faster.

Another often overlooked aspect of cybersecurity is the physical layer. Unlocked doors combined with someone pretending to be IT staff could thwart even the best network security, in some cases resulting in the removal of physical hardware.

After a complete test, a detailed findings report outlines tested processes or systems, compromises found, and recommends remediation action steps. Penetration tests are typically annual and may be performed again after a set of proposed security changes are made.

Types of Pentesting Techniques

Not all penetration tests are performed the same way and may vary depending on the scope of the project and the intended outcome of the test. Let's explore a few different types of penetration testing techniques.

Black Box

Black box testing, also referred to as external penetration testing, gives the ethical hacker little to no early information about the IT infrastructure or security of the company beforehand. Black box tests are often used to simulate an actual cyberattack.

Tests start from outside the network where the tester doesn't know about in-place security systems or local network architecture. Since the simulated attack is blind, these tests can be the most time-consuming.

White Box

White box testing is where the tester has full knowledge of the network infrastructure and security systems in place. While these tests don't mimic what a real outside attack might look like, they are one of the most thorough types of tests you can have performed.

White box tests can also simulate what an inside attack may look like since the tester starts inside the network with insider knowledge of how the network is structured. While white box

testing can be completed quickly due to its transparent nature, enterprise organizations with many applications to test may still have to wait several months for complete results.

Gray Box

Gray box is a blend of the first two techniques and allows the tester partial access or knowledge into the company network. Gray box is often used when testing a specific public-facing application with a private server backend. With this combined information, the tester can attempt to exploit specific services to gain unauthorized access into other parts of the network.

The timeframe for a gray box test is usually less than a black box test, but longer than a white box test due to the testers' limited network knowledge of the network.

Exactly What Gets Tested in a Pentest?

Penetration tests don't have to encompass an entire network and focus on specific applications, services, and methodologies. Tests on larger environments can focus on a particular aspect of the network rather than the entire company as a whole. This focus helps organizations budget for upgrades and make time to implement the necessary remediations after a set of smaller pentests without becoming overwhelmed.

Different areas of a company that may get penetration tested include:

- Web applications
- Wireless networks
- Physical infrastructure
- Social engineering

Web Applications

Organizations use web application penetration testing to prevent bad actors from exploiting vulnerabilities on client-facing apps. These tests can vary in complexity due to the vast amount of different browsers, plugins, and extensions that all come into play when running a pen test on a web application.

Web app vulnerabilities can leak sensitive information that may help attackers during the information gathering stage of an attack or get backend access into a specific application.

Agile code can be used to combat these attacks, along with regular testing in sandbox environments on a web development branch. Even after testing and deployment, penetration testers can bring new exploits to light to help companies avoid an actual real attack.

Bug bounty programs are a great way to incentivize ethical hackers to test the latest exploits against different web applications.

Wireless Networks

The inherent openness of Wi-Fi makes it an attractive target for both curious passersby and dedicated attackers. Penetration testers can use many specialized tools that test the reliability and security of different wireless technologies.

Packet sniffers, rogue access points, and deauthentication attacks can be used to hijack wireless sessions and gain a foothold into a private network. Wireless pen testers can also validate the security settings on a guest Wi-Fi network.

For instance, if access rules aren't configured properly, and the guest network isn't on its own VLAN, an attacker can potentially gain access to the private network from the guest wireless.

Physical Infrastructure

No security software can stop someone from physically picking up a server and walking out the door with it. While that may seem far-fetched, brazen criminals utilize social engineering to masquerade as technicians, janitors, or guests to gain physical access to sensitive areas.

In a physical penetration test, doors, locks, and other physical controls are put to the test to see how easily bad actors can bypass them. They can be bypassed. Cheap locks and wireless motion detectors are often easily picked or bypassed, while cheap wireless motion detectors can be or fooled with a bit of ingenuity.

If physical restrictions are present, a tester will usually use a series of non-destructive tools to attempt to bypass any locks or sensors that are in place.

Social Engineering

Attackers use social engineering to trick staff members into giving privileged information or access to an organization. This access may be in the form of a phishing email, phone call, or someone physically pretending to be someone they're not on site.

The ultimate defense against social engineering is knowledgeable and trained staff. Email phishing training has been shown to reduce the number of malicious emails opened. Having policies and procedures in place for visitors can also prevent unauthorized physical access.

Social engineering tests often take place in email or over the phone. Software platforms can be used to send fake phishing emails consistently. Those who click links or reply can be automatically given remediation training. Over time this type of training helps strengthen both the IT infrastructure and the knowledge of all staff members.

Who Are Pentesters?

Penetration testers are trained in many technical and non-technical skills that allow them to professionally and ethically test client networks. Unlike bug bounty hunters, most penetration testers work full-time rather than as freelancers. You'll often see specialized penetration testing teams made up of members with different skill sets.

Many testers have a deep understanding of programming and know multiple languages that can be used to craft exploits and payloads. In addition to coding, ethical hackers must have a strong knowledge of networking and network protocols. They must understand how real attackers use protocols like DNS, TCP/IP, and DHCP to gain unauthorized access.

Outside of standard technical certifications, there are specialized exams specifically crafted for ethical hackers. One certification called the Certified Ethical Hacker, or CEH, contains 125 multiple choice questions and takes four hours to complete. Many ethical hackers hold this certification alongside other network-related certs.

Penetration testers must also be armed with a set of soft skills to succeed on assignments. Critical thinking and creative problem-solving are a must for ethical hackers, as many attacks will fail or not unfold as expected. Quickly finding creative solutions to challenging problems is part of the job for a penetration tester.

A Piece of a Bigger Puzzle

Penetration testing is only one part of a larger strategy to keep networks secure. Pen testing often occurs over a set period and is complemented by other types of scans and programs that help strengthen the overall security posture of an organization.

For example, bug bounty programs offer a continuous way for companies to discover vulnerabilities and improve their network security long after a penetration test has concluded. These programs reward ethical hackers financially when they successfully find and disclose a vulnerability or security flaw.

Bounty payouts usually scale in size depending on the severity of the vulnerability found. Bug bounties act as an evergreen program that continuously challenges the best and brightest minds to put some of the most secure networks to the test. When comparing bug bounty vs. penetration testing, many organizations find that a mix of both offers the best long-term security strategy.

Regular vulnerability scanning can also complement annual penetration testing to help ensure businesses are staying secure between tests. Vulnerability scans can now be automated and run regularly in the background of a network to help detect potential exploits that a bad actor could use to gain a foothold inside a company. Vulnerabilities usually lurk in outdated software, unpatched systems, and misconfigured networking equipment such as routers or switches.

While regular updates can help fix most vulnerable systems, it only takes one unpatched machine to infect an entire network. For example, the Windows BlueKeep vulnerability made it possible for attackers to break into networks using Remote Desktop Protocol. Once inside, an attacker could move laterally within the network and perform privilege escalation to hijack servers, encrypt files, or steal data.

Vulnerability scans help prevent this by identifying these exploits and bringing them to your attention first. Administrators can then work quickly to prioritize the findings and make the necessary changes to fix the issue.

How HackerOne Can Help

HackerOne's hacker-powered security helps keep businesses safe. Through the largest and most diverse community of hackers in the world, networks can be tested and protected using the latest strategies and techniques. The HackerOne platform gives you a live look into the progress of an ongoing pentest and allows you to track key metrics from kickoff to remediation.

See Our Additional Guides on Key Data Security Topics

Together with our content partners, we have authored in-depth guides on several other topics that can also be useful as you explore the world of [data security](#).

[Data Privacy](#)

Authored by Imperva

- [What is HIPAA Privacy Rule: HIPAA Security Requirements](#)
- [What is Data Governance: Frameworks, Tools & Best Practices](#)
- [SOX Compliance: Requirements, Controls & Audits](#)

Ransomware Data Recovery

Authored by Cloudian

- [Ransomware Backup: How to Get Your Data Back](#)
- [S3 Object Lock — Protecting Data for Ransomware Threats and Compliance](#)
- [2021 Ransomware Attack List and Alerts](#)

DLP

Authored by Exabeam

- [Data Loss Prevention Tools](#)
- [Data Loss Prevention Policy Template](#)
- [Understanding Cloud DLP: Key Features and Best Practices](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?



